

Incident Detection & Response

Brian Olliff

Defensive Engineering Instructor

Key Concepts

- + Incident response fundamentals
- + Detecting incidents
- + Tier 1 analyst incident response
- + Workflows and documentation

MAJOR TOPICS

- + IR teams & processes
- + Events, alerts, incidents
- + Detecting activity
- + Validating alerts
- + Triage and response



LEARNING OUTCOMES

- + Understand the fundamentals of incident response
- + Recognize the difference between events, alerts, and incidents
- + Be able to recognize the difference between suspicious and normal activity
- + Understand the process to effectively triage alerts and events
- + Be able to walk through a full incident response - from detection to escalation

PREREQUISITES

- + Basic cybersecurity fundamentals
- + Basic IT/networking fundamentals

Let's Get Started!

Incident Detection & Response

- + Beginning with understanding the purpose and function of IR

What is Incident Response?



Incident Response

- Investigation
- Containment
- Eradication
- Recovery

Ensuring that threats are effectively neutralized and that systems are restored to normal operations while minimizing damage.

Incident Response Components

Component	Description
Preparation	Establishing an incident response plan, playbooks, and procedures.
Identification & Validation	Confirming the presence of an actual security incident.
Containment	Isolating affected systems and blocking malicious activity to limit the attack's impact.
Recovery	Restoring affected systems and services while validating their security.
Post-Incident Review	Conducting lessons-learned sessions to refine incident response procedures.

Incident Response Teams



Types of Incident Response Teams

**Computer
Security
Incident
Response
Team
(CSIRT)**

**Coordination
Centers**

**Computer
Emergency
Response
Team
(CERT)**

**Product
Security
Incident
Response
Team
(PSIRT)**

**Managed
Security
Service
Providers
(MSSP)**

CSIRT (Computer Security Incident Response Team)

- **Dedicated, structured** team within the org
- Responsible primarily for security incidents
- Well-defined processes
 - Detection
 - Response
 - Mitigation
 - Recovery
- Main goal is to minimize damage and restore operations as quickly as possible

Key CSIRT Responsibilities

Incident Management	Primary contact, coordination of response
Detection & Analysis	Monitoring and analysis of all data
Response & Mitigation	Containment, eradication, mitigation
Threat Intelligence	Collection and analysis of intel
Forensic Analysis	Collection/analysis of all evidence
Recovery & Remediation	Assisting in restoration as needed
Documentation	Record every phase of incident
Reporting	Post-mortem reporting, communication with leadership
Policies & Procedures	IR plans, playbooks, best practices

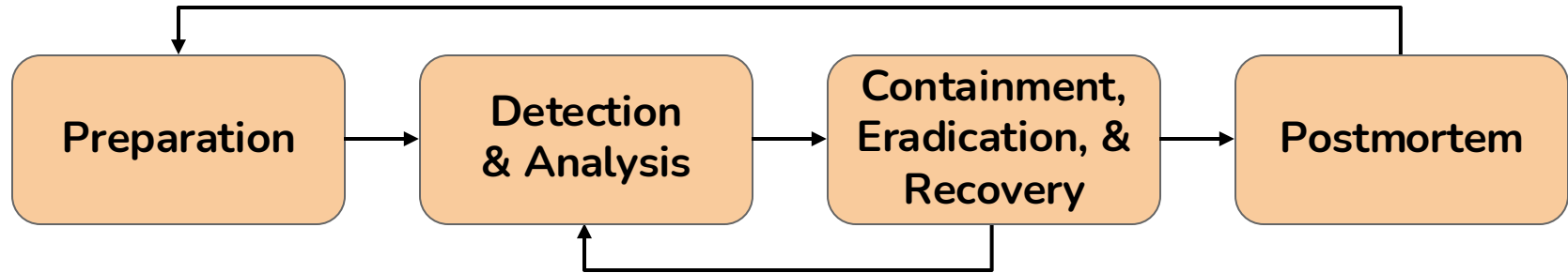
IRT (Incident Response Team)

- Broader definition and responsibilities than CSIRT
 - Some orgs use CSIRT and IRT interchangeably
- May handle both security and non-security incidents
- Frequently staffed by multiple departments
 - IT
 - Legal
 - HR
 - PR
 - Security
- May not be formally established team

Incident Response Process



Incident Response Phases



Detection & Analysis

- Many attacks and breaches can go undetected for days, weeks, months
- Requires effective controls/tools to examine network “blind spots”
- Log collection, correlation, and analysis
 - From hosts, devices, & network
- Appropriate resources and references used
 - Internal knowledge base, Internet resources, intelligence data, other analysts
 - Knowledge of types of attacks, attack vectors, and attackers
- Follow all org policies and procedures
- Incident documentation
- Prioritize incidents based on established processes

Containment, Eradication, & Recovery

- Based on information/intelligence gathered in analysis phase
 - Identification of hosts involved
 - Containment strategy choice to effectively eradicate and recover
- Appropriate strategy determined by:
 - Potential damage to organizational resources
 - Evidence preservation requirements
 - Affected systems and services
 - Required time, effort, resources to implement
 - Strategy effectiveness (partial or full containment)
 - Solution duration (permanent, temporary, emergency)

Post-Incident Activity (Postmortem)

- Lessons learned
- Documentation and review of what happened, where, & when
- Review of responder/staff activities
- Verification of procedure effectiveness, and review of whether followed
- Identify what could have been done differently
 - Any actions that inhibited response or recovery
 - Information sharing that could be improved
 - Events that could have been identified sooner
 - Any additional tools or resources that may be needed
- Acknowledge actions that went well and contributed to recovery efforts

Events, Alerts & Incidents



Events

Any observable occurrence in a system or network

- Raw data
- Typically high volume
- Examples:
 - User logged in/out
 - File opened, modified, deleted
 - DNS request
 - Process created or terminated
- Most events are normal behavior

Alerts

A notification generated by security tools when an event or series of events appears suspicious

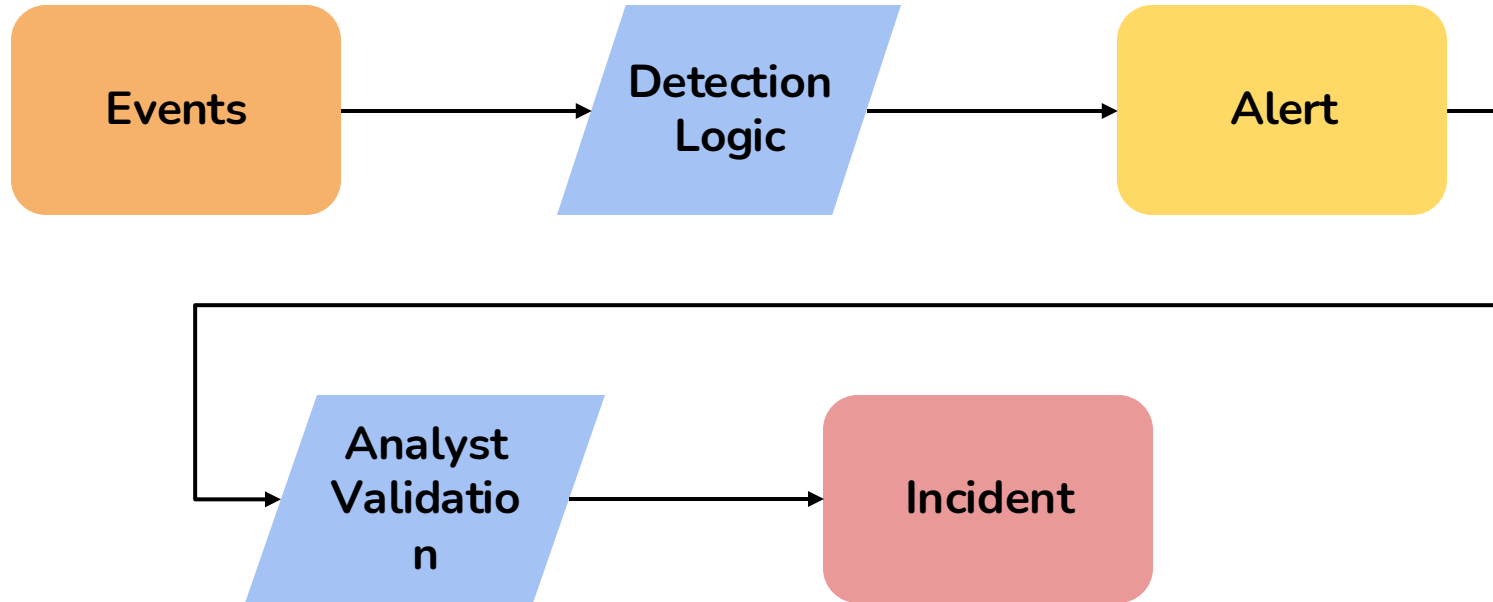
- Events that match
 - Rules/signatures
 - Thresholds
 - Behavior or anomaly definitions/models
- Examples:
 - Multiple failed logins
 - Malware signature detection
- Alerts require validation

Incidents

A security event that has been confirmed or suspected as a threat or attack, requiring response

- Threatens CIA or policy
- Requires active response
- Examples:
 - Confirmed phishing compromise
 - Unauthorized access to data/system
 - Data exfiltration
- Incidents drive IR workflows

Event to Incident



Recap

Term	Description	Volume	Confidence	Action
Event	Raw activity record	Very high	Neutral	Usually none
Alert	Suspicious pattern flagged by tool	Medium	Uncertain	Review & validate
Incident	Confirmed security issue	Low	High	Incident response

Detecting Suspicious Activity



Suspicious Activity

Suspicious ≠ Confirmed

- Only a signal, possibility

Normal -> unusual -> suspicious -> confirmed incident

- Activity that *doesn't fit expectation* or that *raises risk*

Baselines

- Detecting suspicious begins with defining **normal**
- Baselines
 - What's normal/typical for the environment
- Examples:
 - Login hours
 - Locations and IPs
 - Traffic volume
 - Running processes
 - Installed software

Suspicious Pattern Categories

Authentication

Network

**Endpoint &
Processes**

**Data
movement**

**Privilege &
Accounts**

Remember Context

- Privileged users vs normal users
 - Production server vs test/lab
 - Business hours vs holidays
 - “One-off” vs repeated or spreading
-
- Is this unusual for this situation?
 - Is a high-value account or asset involved?
 - Is the behavior repeated, escalating, or spreading?
 - Do multiple data sources agree?

Phishing & Email Compromise



Phishing

- Most common initial access path
- Objectives:
 - Credential theft & account takeover
 - Malware delivery
 - Direct access via OAuth or app access abuse



Common Delivery Methods



Email Indicators

**Domain or
sender
anomalies**

**Mismatched
reply-to
address**

**Coercive
language**

**Sense of
urgency**

Attachments

**Suspicious
links**

Post-Click Indicators

- Authorization anomalies after click
 - New geographic location or device for user
 - Login from “impossible travel” location
 - MFA fatigue patterns
- Changes in mailboxes
 - New forwarding rules
 - Inbox rules hiding or moving messages
 - Unusual permissions granted
- Unusual outbound activity
 - Spike in sent messages
 - Internal phishing messages from user

Credential & Account Attacks



Account Compromise

- Attempts to gain access to accounts
 - Typically using stolen or guessed credentials
- Goal of account takeover
 - Pivot to other systems (lateral movement)
 - Elevate access to root/admin accounts (privilege escalation)
- Many incidents start here without any malware

Common Types of Account Attacks

**Brute force
attacks**

**Password
spraying**

**Credential
stuffing**

**MFA fatigue &
abuse**

Failure Indicators

- **Multiple authentication failures**
- Brute force
 - Repeated failures for single account
- Password spraying
 - Multiple failures across many accounts
- Credential stuffing
 - Many accounts with fewer failures, typically followed by success
- MFA abuse
 - Multiple push notifications
 - User denying prompts

Success Indicators

- **Multiple authentication failures followed by a success**
- Login from new device
- Impossible travel
- Repeated MFA prompts within minutes
 - Followed by one approval
- Changes to MFA configuration

- Can lead to
 - Privilege escalation
 - Lateral movement
 - Configuration changes

Malware & Endpoint Compromise



Endpoint Compromise

Endpoint compromise = attacker activity in network

- EDR/AV Alerts
- Suspicious processes or scripts
- Network “callback” traffic
- User-reported symptoms

Indicators

**Process
Execution**

**Files and
Artifacts**

Persistence

**Network
Indicators**

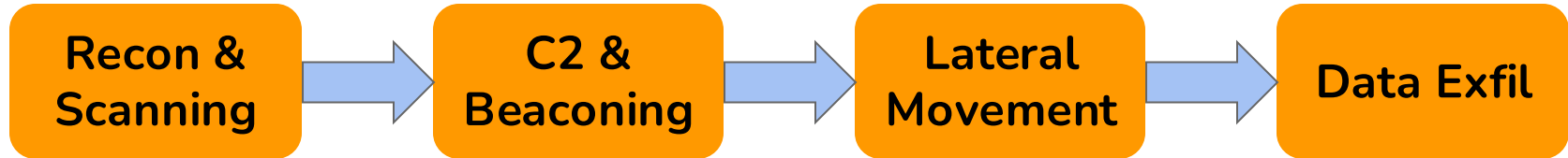
Network Intrusions



Network Intrusion

Suspicious network behavior indicating attacker activity

- Typically seen as patterns, not single events
- Indicators frequently connect multiple systems



Reconnaissance and Scanning

- Port scans
 - Host sweeps
 - Internal recon
 - IDS or firewall indicators
-
- Remember approved vulnerability scanners

Command and Control Beaconsing

- Periodic callbacks
 - Beaconsing - repeated outbound connections at regular intervals
- Rare domains and IPs
 - Domains and other destinations never seen before in org
 - Rare TLDs
 - Newly registered domains
- Odd ports and protocols
 - HTTP(S) traffic to unusual paths or unusual user-agents
 - DNS tunnels
 - TLS connections to IPs or using self-signed certs

Lateral Movement

- Account hopping
 - One user authenticating to multiple hosts
- Remote execution and administration
 - Suspicious use of embedded protocols or third-party tools
- Access to admin shares
 - C\$, ADMIN\$, IPC\$
- Windows authentication anomalies
 - Kerberos/NTLM

Data Exfiltration

- Increase in data transfer volume
 - Compared to baseline
- Timing of outbound traffic
 - Spike in traffic after other activity
 - Outside normal business hours
- Unusual destinations
 - Abnormal storage services, personal cloud, rare domains
- Behavioral combinations
- Still only suspicious until confirmed

Contextualizing & Validating Alerts



Validation

- Confidence check
 - Is the alert meaningful?
 - What action is required next?
- Decision point
 - Close or escalate
- Not a deep investigation

Alert Context

Why is context important?

Internal Data

Asset criticality

User/role context

Change management

Known “safe” lists

Baselines & Anomalies

Comparison to “normal”

Unusual ≠ malicious

Risk context?

Threat Intelligence

Reputation checks

Known bad indicators

Prior sightings

Context Checklist

- 1. What does the alert actually say?
- 1. Do supporting logs agree?
- 1. Internal context
- 1. Is this out of baseline norms for user/host?
- 1. Any TI or reputation data confirm known bad?
- 1. What is the safest decision?

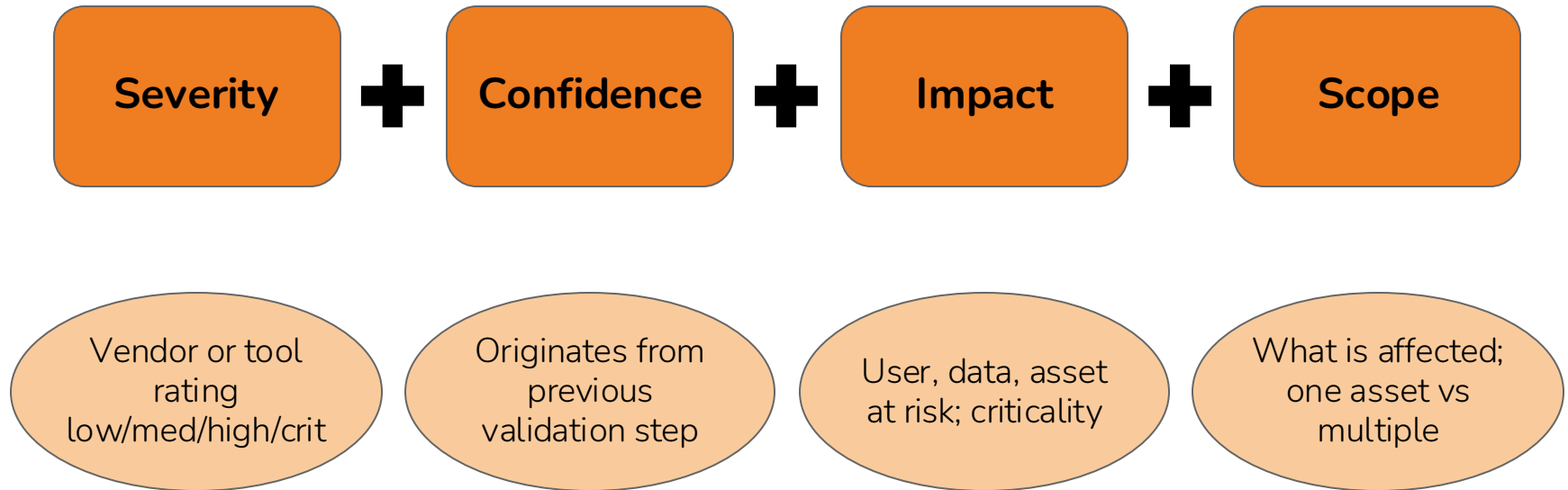
Triaging Alerts



Triage

- Step right after adding context and validating
- Validation - “Is this likely real?”
- Triage - “How urgent is it, and where does it go?”
 - Rapid prioritization and routing
 - **Not** full investigation
 - **Not** containment
 - **Not** playbook execution

Priority Determination



Priority Levels

Priority	Description	Typical Action
P1	Critical	Immediate escalation
P2	High	Urgent review/escalation
P3	Medium	Standard queue
P4	Low	Monitor/close if benign

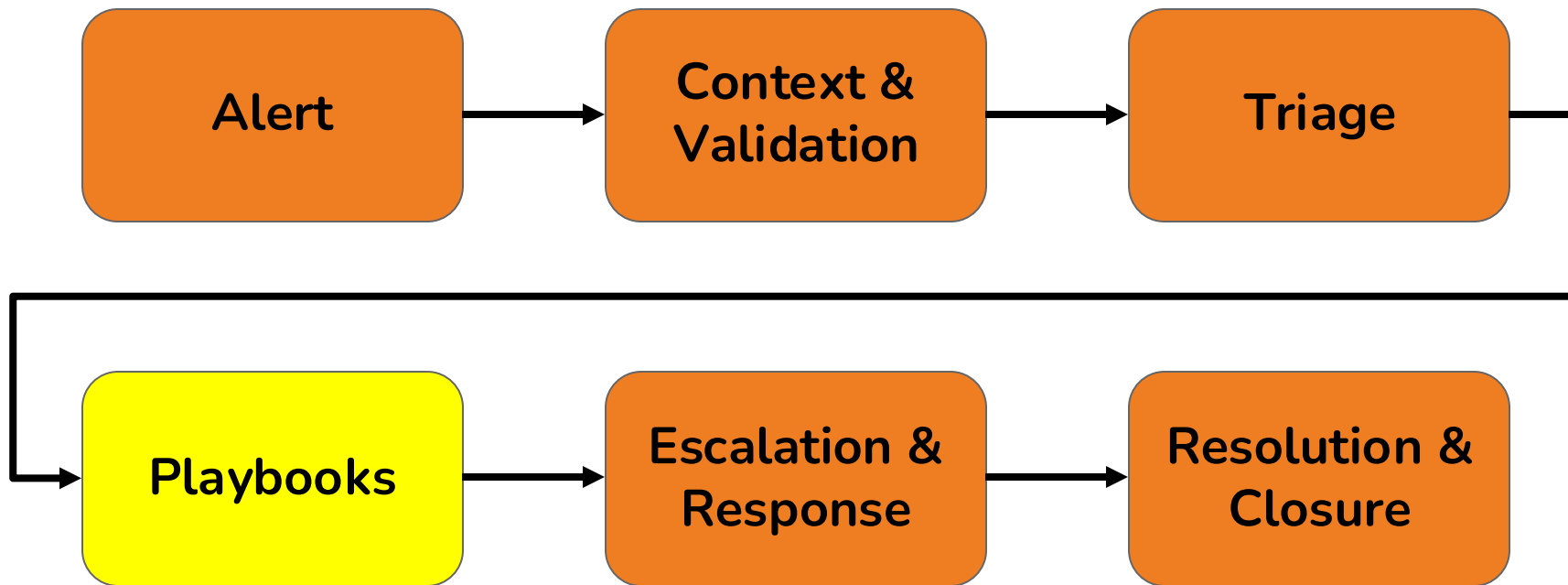
Incident Response Playbooks



Playbooks

- Documented, repeatable response steps
- Typically built for specific incident types
 - Ransomware
 - Data exfil
 - Multiple account compromise
 - Phishing
 - Insider activity
- Designed to ensure consistency and efficiency/speed
- SOC L1 only expected to **use**, not write

Playbooks in the Workflow



Tier 1 Actions

- Follow assigned steps
- Gather specified evidence
- Perform ***approved*** actions
- Escalate at specific decision points
- Document outcomes

Example Playbooks

Potential Phishing Incident

1. Confirm email details
2. Check for user interaction
 - a. If user entered creds, escalate
3. Look for related auth anomalies
 - a. If found, escalate
4. Escalate if specific compromise indicators
5. Document and escalate or close

Malware Detection

1. Review EDR alert & processes
2. Identify host/user & scope
3. Check for network callbacks
 - a. If C2 traffic found, escalate
4. Document and escalate or close

Documenting & Reporting for Incident Response



Incident Response Documentation

- IR documentation used in more places
- More detailed and higher quality than ticket
- Must be reproducible
- Neutral findings
 - Facts first
 - Separate observation from interpretation
 - Avoid assumptions
- Build a timeline
- Preserve evidence
- Record decisions & rationale
- Enable hand-offs and lessons learned

Tier 1 Responsibility

- Who, what, when, where
 - Key indicators
 - Scope information
 - Actions taken
-
- Every note must include timestamp
 - Detection time
 - Observed activity time
 - Action time

Evidence

**Don't alter
evidence**

**Note the source
& method**

**Keep raw data &
artifacts**

Follow org SOP

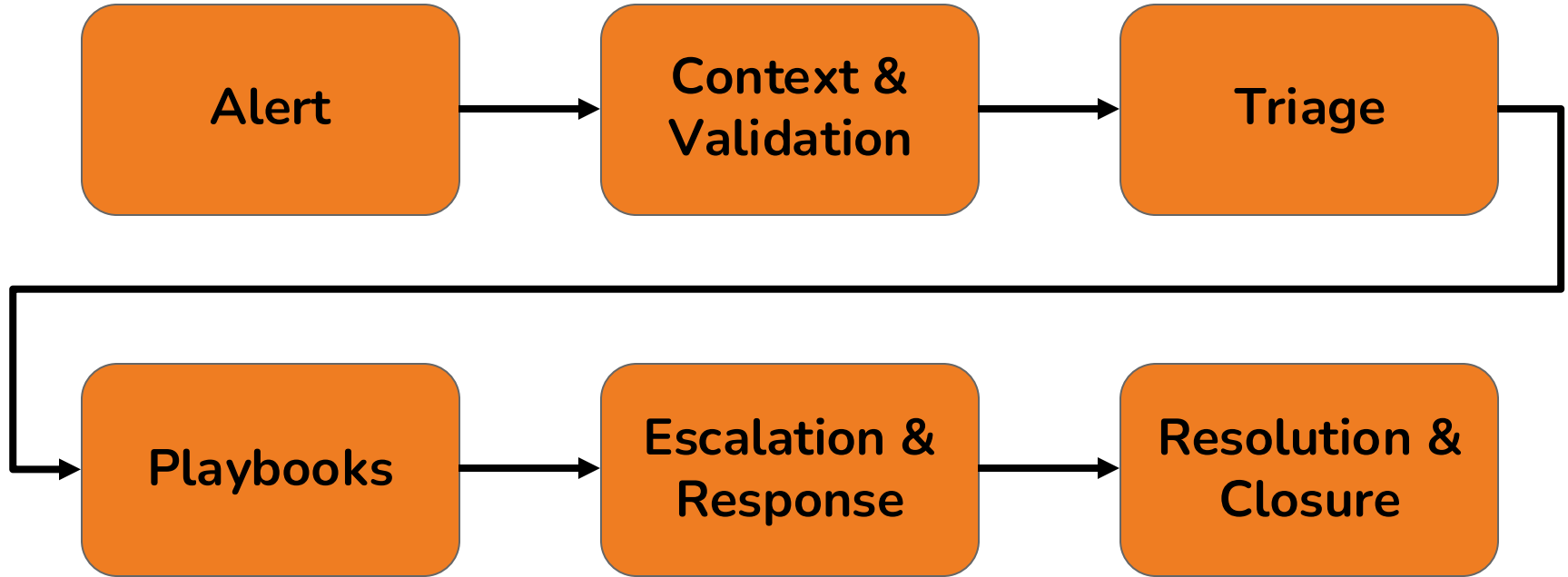
Additional Notes

- Why incident was escalated or closed
- Confidence level
- Any recommendations

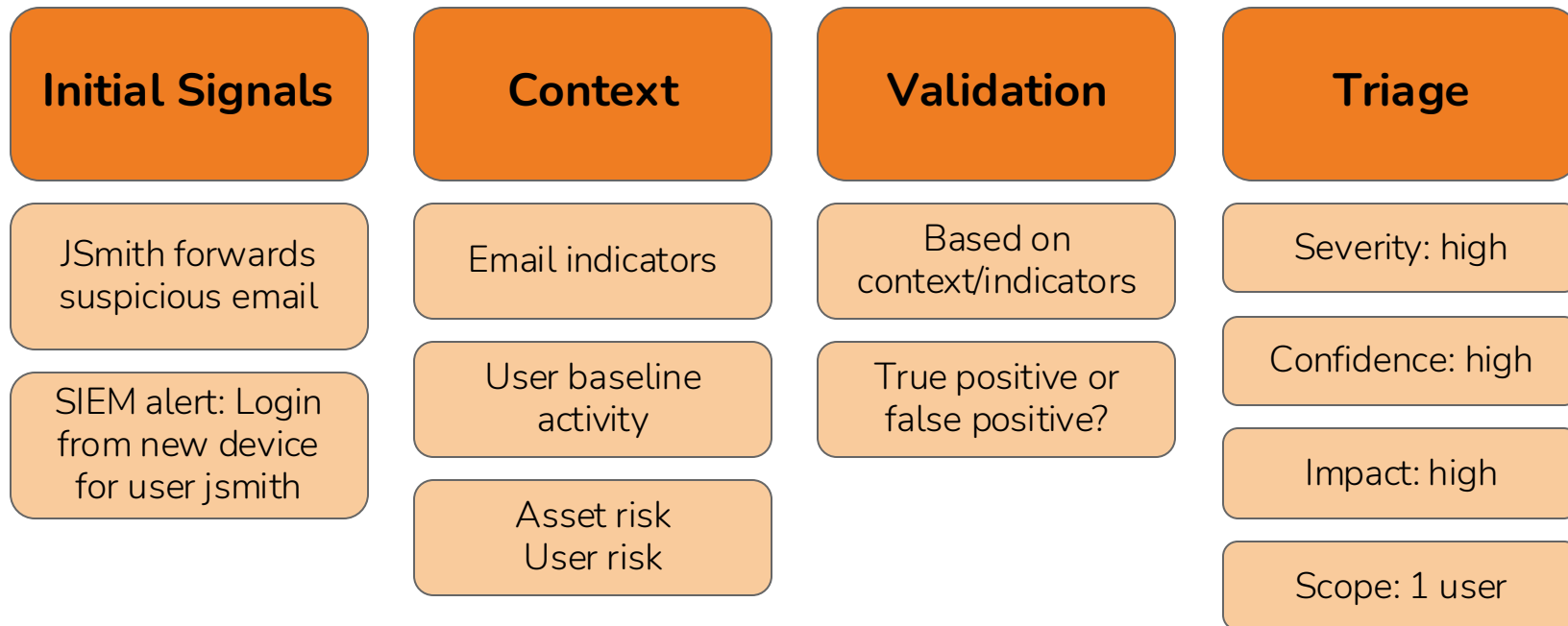
Tier 1 Incident Workflow



Workflow



Possible Phishing



Phishing Incident Playbook

1. Confirm suspicious nature of email
1. Confirm user clicked suspicious link
 - a. If clicked, confirm if user entered credentials
1. Gather timeline of authentication event(s)
 - a. If suspicious login, **disable account**
1. Check user mailbox for unauthorized changes
 - a. Rule changes/additions
 - b. OAuth grants
1. Escalate to T2 for further investigation
 - a. Ensure relevant info entered into ticket
 - i. timeline (with timestamps)
 - ii. applicable indicators
 - iii. scope status

Incident Detection & Response - Summary

Key Concepts - Recap

- + Incident response fundamentals
- + Detecting incidents
- + Tier 1 analyst incident response
- + Workflows and documentation



Learning Outcomes Recap

- + Understand the fundamentals of incident response
- + Recognize the difference between events, alerts, and incidents
- + Be able to recognize the difference between suspicious and normal activity
- + Understand the process to effectively triage alerts and events
- + Be able to walk through a full incident response - from detection to escalation

Next Steps

- + Continue with SOC Analyst Level 1 learning path
- + Additional courses on security basics
- + Research and practice with recognizing suspicious events
- + Try your hand at writing and understanding playbooks
- + Labs in Skill Dive

Thank you!

Incident Detection & Response

- + Thank you for your time!

EXPERTS AT MAKING YOU AN EXPERT

